정보보안기사 실기 22회 — 문제와 답안

원본: newbt.kr 복원 기출 (3.pdf). 답안은 복원 문항 기준의 모범 답안이며 공식 정답이 아니다.

---

1. 라우팅 프로토콜에 대한 설명이다. ( )에 들어갈 프로토콜명을 기술하시오.

1) (A) : 거리 벡터 알고리즘을 사용하며, 가장 오래되고 널리 사용되는 내부 라우팅 프로토콜
2) (B) : 링크 상태 알고리즘을 사용하며, 링크 상태 변화시에만 라우팅 정보를 교환하는 내부 라우팅 프로토콜
3) (C) : 시스코에서 제안하였으며, 거리벡터와 링크 상태 알고리즘의 장점을 수용한 하이브리드 라우팅 프로토콜. 효율성과 수렴 속도가 개선되어 안정적인 라우팅을 지원함.

답안

A RIP · **B** OSPF · **C** EIGRP

2. 다음 ( ) 에 들어갈 유닉스 로그 파일명을 기술하시오(경로는 생략해도 됨)

1) (A) : 사용자의 가장 최근 로그인 시각, 접근 호스트 정보 기록
2) (B) : SU(Swift User) 권한 변경(성공 or 실패) 로그 기록
3) (C) : 시스템에 로그인한 모든 사용자가 실행한 명령어 정보 기록

답안

A lastlog · **B** sulog · **C** pacct(acct)

3. 유닉스의 /etc/passwd에 등록된 정보이다. 밑줄 친 값의 의미를 설명하시오.

(정보) test01:x:100:1000:/home/exam:/bin/bash
1) 1000 : (A)
2) /home/exam : (B)
3) /bin/bash : (C)

답안

A 그룹 ID(GID) · **B** 사용자의 홈 디렉터리 · **C** 로그인 셸(로그인할 때 실행되는 셸)

4. HTTP Request 입력값에 개행문자가 포함되면 HTTP 응답이 2개 이상으로 분리되어, 공격자는 첫 응답을 종료시킨 후 다음 응답에 악의적인 코드를 삽입/실행할 수 있는 HTTP 응답 분할 공격이 가능해진다. 위에서 언급한 개행 문자 2가지를 기술하시오.

답안

CR(Carriage Return, `\r`, `%0D`) · **LF**(Line Feed, `\n`, `%0A`)

5. 파일 삽입 취약점은 공격자가 악성 스크립트를 서버에 전달하여 해당 코드가 실행되도록 할 수 있다. PHP를 사용하는 경우 이에 대한 대응책에 대하여 ( )에 들어갈 값을 기술하시오.

1) PHP 소스 코드에 (A) 함수가 존재하는지 확인
2) PHP 설정 파일 (B)에서 allow_url_fopen 값을 (C)로 설정

답안

A `include` (include_once·require·require_once 포함) · **B** `php.ini` · **C** `Off`

6. Snort에서는 대량의 패킷에 대응하기 위하여 Threshold 옵션을 type(action 수행 유형), track(소스/목적지 IP), count(횟수), second(시간)으로 설정할 수 있다. 이 중 threshold type 3가지를 기술하시오.

threshold type , track, count , seconds

답안

limit · **threshold** · **both**

limit은 기간 안에 처음 count번만 알린다. threshold는 count번마다 알린다. both는 기간 안에 count번에 이르면 한 번만 알린다.

7. ARP request 요청을 보내는 경우 목적지 주소를 형식에 맞춰서 기술하시오.

답안

`FF:FF:FF:FF:FF:FF` (브로드캐스트 MAC 주소)

ARP 요청은 상대 MAC을 모르므로 이더넷 목적지를 브로드캐스트로 보낸다. ARP 패킷 안의 Target MAC 필드는 `00:00:00:00:00:00`으로 비워 둔다.

8. DNS 서비스와 관련하여 ( )안에 들어갈 용어를 기술하시오.

1) DNS 서비스는 53번 포트를 사용하고 전송 계층 프로토콜로 (A) 를 사용한다.
2) DNS 서버는 반복적인 질의로 상위 DNS에 가해지는 부하를 줄이기 위해 (B) 를 사용하는데, 해당 정보가 유지되는 기간을 (C) 이라고 한다.

답안

A UDP · **B** 캐시(DNS 캐싱) · **C** TTL(Time To Live)

영역 전송이나 512바이트를 넘는 응답에는 TCP 53도 쓴다.

9. 애플리케이션의 소스 코드를 보지 않고 외부 인터페이스나 구조를 분석하여 취약점을 발견하는 방식을 (A)라 하고, 개발된 소스 코드를 살펴봄으로써 코딩 상의 취약점을 찾는 방식을 (B) 라고 한다.

답안

A 블랙박스 테스트 · **B** 화이트박스 테스트(소스코드 진단)

10. SW 개발과정에서 DBMS 조회를 위한 질의문 생성 시 사용되는 입력값과 조회 결과에 대한 검증방법(필터링 등)을 설계하는 경우 고려해야 할 사항이다. ( ) 에 들어갈 용어를 기술하시오.

1) 애플리케이션에서 DB연결을 통해 데이터를 처리하는 경우 (A)이 설정된 계정을 사용해야 한다.
2) 외부 입력값이 삽입되는 SQL 쿼리문을 (B)으로 생성해서 실행하지 않도록 해야 한다.
3) 외부 입력값을 이용해 동적으로 SQL 쿼리문을 생성해야 하는 경우, (C)에 대한 검증을 수행한 뒤 사용해야 한다.

답안

A 최소 권한 · **B** 동적 · **C** 입력값(외부 입력값)

11. 개인정보의 안전성 확보조치 기준에 대하여 ( )에 들어갈 용어를 기술하시오.

[제8조(접속기록의 보관 및 점검)] ① 개인정보처리자는 개인정보취급자가 개인정보처리시스템에 접속한 기록을 (A) 년 이상 보관·관리하여야 한다. 다만, (B) 명 이상의 정보주체에 관하여 개인정보를 처리하거나, 고유식별정보 또는 (C) 를 처리하는 개인정보처리시스템의 경우에는 2년 이상 보관·관리하여야 한다.

답안

A `1` · **B** `5만` · **C** 민감정보

12. 위험관리와 관련하여 ( )에 들어갈 용어를 기술하시오.

1) (A) : 내외부 위협과 취약점으로 인해 자산에서 발생 가능한 위험을 감소시키기 위한 관리적, 물리적, 기술적 대책
2) (B) : (A)을 적용한 이후에 잔재하는 위험
3) (C) : 조직에서 수용 가능한 목표 위험 수준을 의미하며 경영진의 승인을 받아 관리해야 함

답안

A 정보보호대책(보호대책) · **B** 잔여 위험(Residual Risk) · **C** DoA(Degree of Assurance, 목표 위험 수준)

13. BYOD 환경에서 모바일 오피스 서비스를 하려고 한다. 관련된 다음의 3가지 보안 기술에 대하여 설명하시오.

1) MDM(Mobile Device Management)
2) 컨테이너화
3) 모바일 가상화

답안

1) MDM: 관리 서버가 등록된 모바일 기기를 원격으로 관리한다. 보안 정책 적용, 앱 배포와 통제, 카메라 같은 기능 제한, 분실 시 원격 잠금과 데이터 삭제를 한다.
2) 컨테이너화: 단말 안에 암호화된 업무 전용 영역(컨테이너)을 따로 만들어 개인 영역과 분리한다. 업무 데이터와 앱만 통제하고 삭제할 수 있어 개인 사생활을 침해하지 않는다.
3) 모바일 가상화: 하이퍼바이저로 한 단말에서 업무용과 개인용 운영 환경을 독립적으로 실행한다. 두 환경이 완전히 격리되어 한쪽의 악성코드나 유출이 다른 쪽에 영향을 주지 않는다.

14. 다음의 위험 분석 방법에 대하여 개념과 장단점을 설명하시오.

1) 기준선 접근법
2) 상세 위험 분석법

답안

1) 기준선 접근법
개념: 모든 시스템에 표준화된 보안 대책 목록(체크리스트)을 기준으로 기본 수준의 보호를 일괄 적용한다.
장점: 분석에 드는 시간과 비용이 적고 쉽게 적용할 수 있다.
단점: 조직 특성을 반영하지 못해 과보호나 보호 부족이 생길 수 있다. 환경 변화에 대응하기 어렵다.
2) 상세 위험 분석법
개념: 자산 분석, 위협 분석, 취약성 분석을 거쳐 위험을 정밀하게 평가하고 대책을 고른다.
장점: 조직에 맞는 적정 보안 수준을 정확하게 정할 수 있다.
단점: 시간과 비용이 많이 들고 전문 인력이 필요하다.

15. 다음의 쿠키 설정값의 의미를 보안 측면에서 설명하시오.

1) Secure
2) HttpOnly
3) Expires

답안

1) Secure: HTTPS 연결에서만 쿠키를 전송한다. 평문 구간의 스니핑으로 쿠키가 탈취되는 것을 막는다.
2) HttpOnly: 자바스크립트(`document.cookie`)가 쿠키에 접근하지 못하게 한다. XSS로 세션 쿠키를 훔치는 것을 막는다.
3) Expires: 쿠키의 만료 일시를 정한다. 지정하지 않으면 브라우저를 닫을 때 지워지는 세션 쿠키가 된다. 만료를 길게 두면 디스크에 남은 쿠키가 탈취·재사용될 위험이 커지므로 짧게 둔다.

16. DNS 증폭 공격에 사용되는 IP 공격 기법을 설명하고, 해당 공격 기법을 사용하는 이유를 설명하시오.

답안

기법: IP 스푸핑. 공격자가 DNS 질의 패킷의 출발지 IP를 공격 대상(피해자)의 IP로 위조해 여러 DNS 서버에 보낸다.
이유: ANY처럼 응답이 큰 질의를 보내면 작은 요청이 몇십 배 큰 응답으로 바뀌어 피해자에게 몰린다. 응답이 공격자가 아니라 피해자에게 가므로 공격을 증폭시키면서 공격자의 위치도 숨길 수 있다.

17. 다음의 HTTP Request 로그를 보고 물음에 답하시오.

[HTTP request]
GET /member/login.php?user_id=1' or '1' = '1'# &user_pw=foo HTTP/1.1
GET /member/login.php?user_id=1' or '1' = '1 &user_pw=foo HTTP/1.1

1) 해당 취약점은 무엇인가?
2) 그렇게 판단한 이유는?
3) 대응 방안은?

답안

1) SQL 인젝션(인증 우회)
2) `user_id`에 작은따옴표로 문자열을 닫고 `or '1'='1'`을 넣어 WHERE 조건을 항상 참으로 만든다. 첫 요청은 `#`으로 뒤의 비밀번호 조건을 주석 처리하고, 둘째 요청은 따옴표 짝을 맞춰 구문 오류를 피한다. 그래서 비밀번호 없이 로그인된다.
3) PreparedStatement 같은 바인딩 변수로 쿼리를 만든다. 입력값의 `'` · `#` · `--` 같은 특수문자를 검증·필터링한다. DB 오류 메시지를 노출하지 않고, DB 계정에 최소 권한만 준다.

18. 개인 정보의 기술적, 관리적 보호 조치 기준에서 요구하고 있는 보호 조치 5가지를 기술하시오.

답안

1. 내부관리계획의 수립·시행
2. 접근통제
3. 접속기록의 위·변조 방지
4. 개인정보의 암호화
5. 악성프로그램 방지

이 밖에 물리적 접근 방지, 출력·복사 시 보호조치, 개인정보 표시 제한 보호조치도 있다.